Secure Purview Baseline Starter Kit

Disclaimer

This document and the Secure Purview Baseline Starter Kit were authored by Daniel Metzger in an individual professional capacity. Although the author is an employee of Microsoft, this material is not an official Microsoft product, release, publication, commitment, or support statement and has not been formally endorsed or published by Microsoft.

The content is based on publicly available Microsoft documentation and field experience of the author and is provided for informational and implementation-planning purposes only, without warranties or guarantees of any kind. Microsoft products, services, features, licensing, and interfaces may change. Organizations remain responsible for validating the guidance against current public Microsoft documentation, applicable licensing terms, security and compliance requirements, and their own environment before deployment.

The Secure Purview Baseline Starter Kit should be tested in a non-production tenant and reviewed by appropriately authorized technical, security, compliance, privacy, and legal stakeholders before production use. Neither the author nor Microsoft accepts responsibility for loss, damage, service interruption, compliance outcomes, or other consequences arising from the use or modification of this material.

Summary

The Secure Purview Baseline Starter Kit provides an implementation-ready starting point for deploying Microsoft Purview data-security controls in a Microsoft 365 tenant. It reduces initial design effort by establishing a coherent baseline for sensitivity labels, label publishing, data loss prevention, Endpoint DLP, message encryption, Insider Risk Management, and Adaptive Protection while retaining clear points for customer-specific validation and tuning.

The starter kit creates a compact sensitivity-label taxonomy spanning Personal, Public, General, Confidential, and Highly Confidential classifications. Confidential and Highly Confidential include purpose-specific sublabels for organization-wide access, named recipients, and approved unencrypted NDA collaboration. One all-users label policy publishes the taxonomy, applies Confidential\All Employees as the default for documents, applies General as the default for email and meetings, requires labeling and downgrade justification, and aligns attachment and container-

The DLP baseline deploys DLP-01 through DLP-10 in TestWithNotifications mode across Exchange, SharePoint, OneDrive, Teams, and endpoints. DLP-11, named Endpoint DLP - Unlabeled to USB, is enabled and blocks unlabeled files from being copied to USB storage. The rules use sensitive information types resolved from the tenant catalog to address external sharing, anonymous links, unapproved guest domains, regulated personal and financial data, credentials, endpoint egress, restricted applications, Teams messages, and Copilot-related content; DLP-11 instead uses the unlabeled-content condition.

Platform preparation is included. The starter kit enables sensitivity-label processing for Office files in SharePoint and OneDrive, triggers container-label synchronization, and enables Exchange internal licensing when the required service plans are available. It configures Windows and macOS path exclusions and sets the Endpoint DLP cloud-app mode to Block. Browser and service-domain restrictions, restricted application groups, VPN definitions, evidence collection, approved partner domains, and other tenant-specific Endpoint DLP settings remain deliberate portal follow-up tasks.

Where licensing and available management interfaces permit, the starter kit also configures Microsoft Purview Message Encryption, attempts to create three Insider Risk Management policies, and enables Adaptive Protection. Policy indicators, triggering events, priority user groups, thresholds, branding text, and related tenant-specific settings must be reviewed and completed in the Microsoft Purview portal.

The deployment is designed to be repeatable and resilient. Existing objects are reused or updated where supported, pending-deletion conflicts and unresolved sensitive information types are reported, and unavailable licensed capabilities are skipped rather than causing the entire deployment to fail. A final deployment summary records created and existing objects, label identifiers, failures, licensing gaps, and the actions required before enforcement.

The Secure Purview Baseline Starter Kit should be treated as a validated starting configuration rather than a universal final design. Organizations should test it in a non-production tenant, confirm the taxonomy and protection behavior against business and regulatory requirements, onboard endpoint devices, complete the documented portal configuration, populate approved exceptions, review policy matches and user impact, and move policies from test to enforcement only after the results are understood and accepted.

Design Principles: Secure by Default

Microsoft engineering recommends reversing the traditional "crawl-walk-run" model: protect everything by default from the outset, then teach users to manage exceptions instead of deciding when protection is needed.


Secure Purview Baseline Starter Kit
1
Platform Enablement
Exchange Online + Security & Compliance PowerShell connections; Microsoft Graph authorization code with PKCE; SharePoint and OneDrive label processing; container-label synchronization; Exchange internal licensing when supported.
2
Sensitivity Labels and Publishing
Labels: Personal, Public, General; Confidential: Anyone NDA (No Encryption), All Employees, Specific People; Highly Confidential: All Employees, Specific People. One all-users label policy. Defaults: documents = Confidential\All Employees; email/meetings = General. Mandatory labeling + downgrade justification. No auto-labeling policies.
3
DLP Enforcement
SIT-based rules, not label-condition rules. DLP-01 through DLP-10 in TestWithNotifications across Exchange, SharePoint, OneDrive, Teams, and endpoints. Additional enabled policy: Endpoint DLP - Unlabeled to USB.
4
Licensed and Supported Capabilities
OME configuration; three Insider Risk Management policies; Adaptive Protection. Capabilities are attempted/enabled only when licensed and supported, with skips reported.
5
Portal Follow-Up
Browser and service-domain restrictions; restricted app groups; VPN; evidence collection; approved partner domains; IRM indicators and triggers; priority user groups; thresholds; OME branding text.
Deployment Summary
Created/existing objects; label identifiers; errors; license skips; next steps.

Figure 1: Secure Purview Baseline Starter Kit architecture – platform enablement supports five required parent sensitivity labels (Personal, Public, General, Confidential, and Highly Confidential) and one all-users publishing policy. Tenant-resolved sensitive information types drive DLP-01 through DLP-10 in TestWithNotifications mode, while DLP-11 (Endpoint DLP - Unlabeled to USB) is enabled and blocks unlabeled files from being copied to USB. Message encryption, Insider Risk Management, and Adaptive Protection are configured when licensed and supported; tenant-specific Endpoint DLP, IRM, branding, and exception settings remain portal follow-up tasks.

Prerequisites and Connections

The Secure Purview Baseline Starter Kit requires ExchangeOnlineManagement 3.4 or later. It uses interactive connections to Exchange Online and Security & Compliance PowerShell. Microsoft Graph access is performed through an interactive authorization-code flow with PKCE on localhost port 8400, requesting SharePointTenantSettings.ReadWrite.All and Organization.Read.All. It does not use the Microsoft Graph PowerShell SDK.

Tenant Enablement

The starter kit enables SharePoint and OneDrive sensitivity-label processing, runs container-label synchronization, and enables Exchange internal licensing when the tenant is licensed for the capability. It detects active service plans and skips and reports unsupported RMS, Exchange IRM, Insider Risk Management, and Adaptive Protection capabilities rather than failing the deployment.

Implementation Prerequisites

Before deployment, confirm the required licenses and permissions, onboard Windows and macOS devices for Endpoint DLP, and use a non-production tenant for validation. The starter kit installs the required Exchange Online module when needed, uses interactive Exchange Online and Security & Compliance connections, and obtains Microsoft Graph access through PKCE without requiring the Microsoft Graph PowerShell SDK. Capabilities that are not licensed or exposed by the available management interfaces are skipped and reported.

Sensitivity Label Taxonomy

The recommended taxonomy is a field-informed variation of the Microsoft internal taxonomy, adapted to reflect implementation experience and common customer requirements. It retains the five-class structure while removing sublabels that have proved unnecessary or inconsistent with the intended protection level. In particular, Highly Confidential has no unencrypted sublabel: every Highly Confidential option applies encryption so that access remains controlled and content stays under organizational protection.

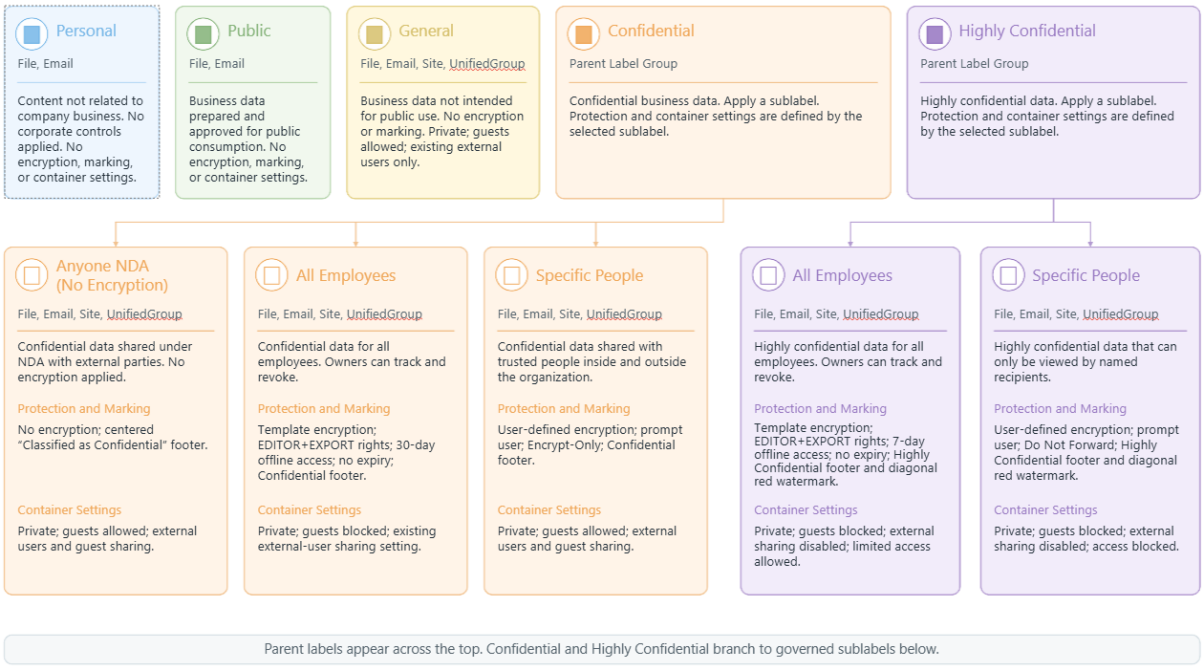
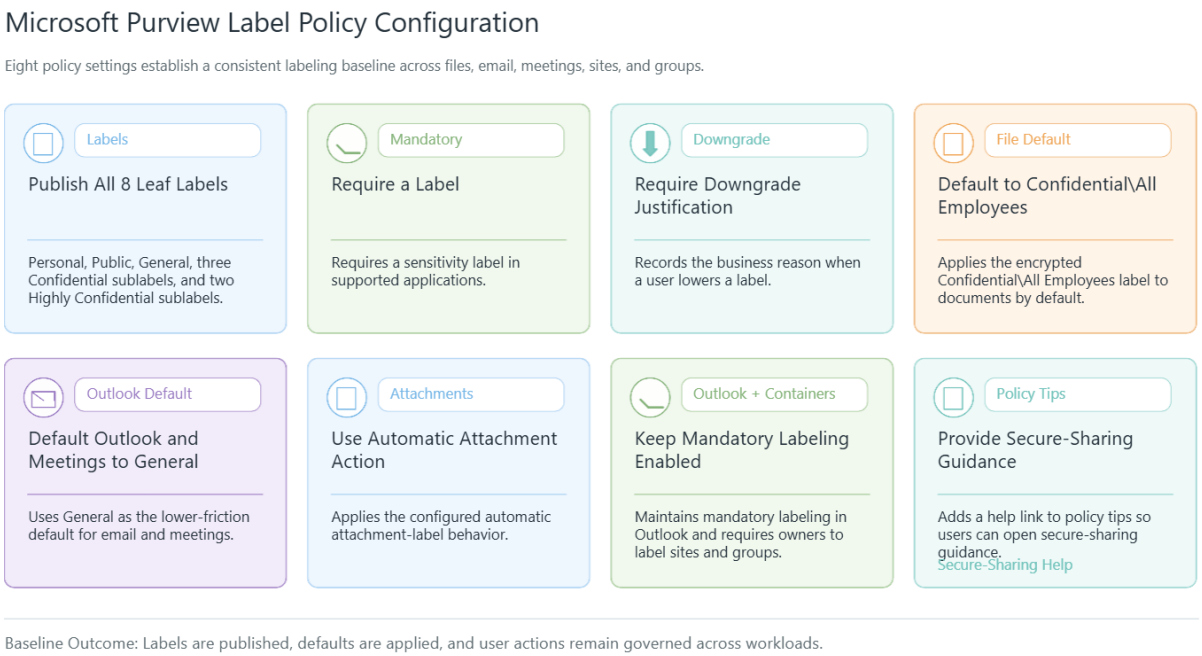


Figure 2: Baseline sensitivity-label taxonomy – five required parent labels: Personal, Public, General, Confidential, and Highly Confidential. Confidential and Highly Confidential contain the implemented sublabels. Personal is part of the baseline and is not optional.

Label Policy (Publishing Strategy)

The baseline makes the complete set of eight usable labels available to all users through one organization-wide publishing policy. This gives every user the same classification choices and applies consistent defaults and mandatory-labeling behavior across documents, email, meetings, SharePoint, OneDrive, and Microsoft 365 groups. A single policy keeps the base configuration easy to understand, operate, test, and update, while avoiding overlapping policies, conflicting settings, and inconsistent user experiences. It also establishes a clear common foundation: additional policies should be introduced only when a defined user group or business scenario requires settings that intentionally differ from the organizational baseline.



Auto-Labeling

The Starter Kit does not create auto-labeling policies. This is intentional: automatic classification depends on each organization's data patterns, regulatory scope, false-positive tolerance, and confidence in the selected sensitive information types or classifiers. The baseline first establishes a consistent taxonomy, mandatory labeling, and default labels so users and administrators can observe how information is classified before automated decisions are introduced.

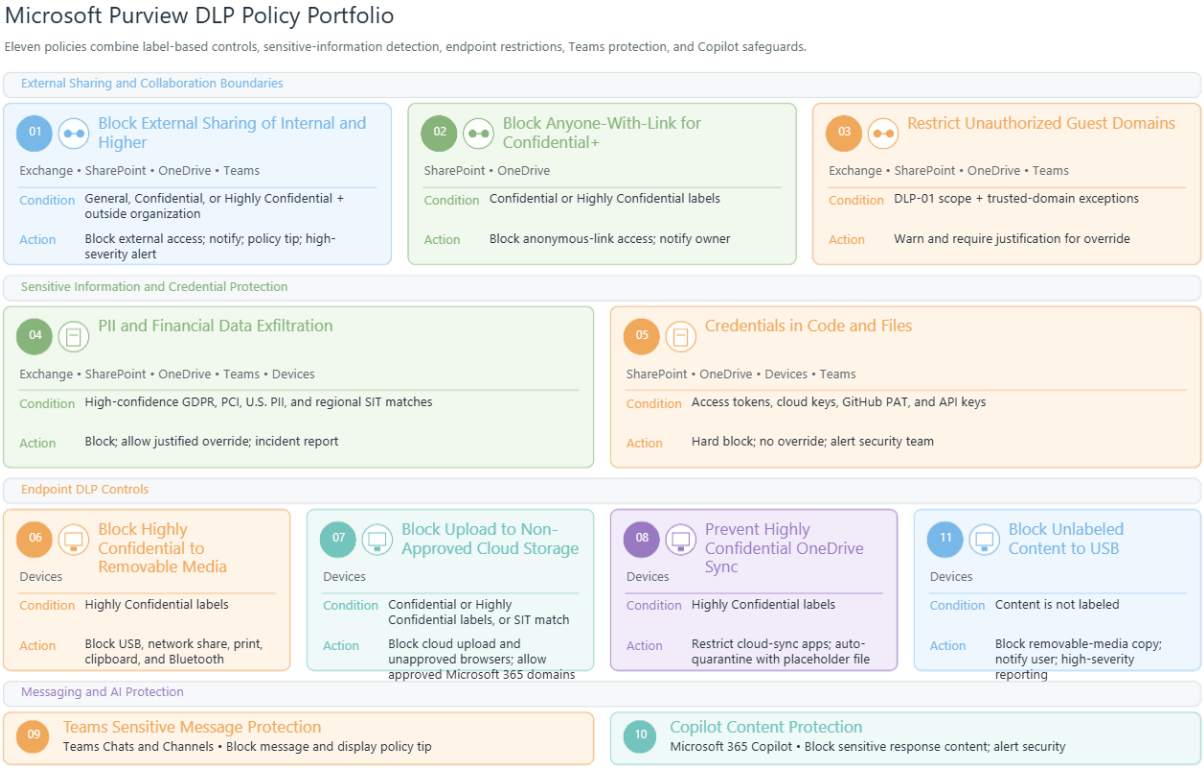
After the baseline has been validated, administrators can add tenant-specific auto-labeling policies as a separate phase. Candidate conditions should be tested in simulation, match results should be reviewed, and counts, confidence levels, scopes, exceptions, and target labels should be tuned before automatic application is enabled. This keeps the starter configuration predictable while providing a controlled path to more automated classification.

DLP Baseline – The "80% Ruleset"

This is the "80% ruleset" because it addresses the data-loss scenarios that repeatedly account for most initial customer requirements: external sharing, anonymous links, unapproved guest destinations, regulated personal and financial data, exposed credentials, endpoint transfers, unapproved cloud services and applications, sensitive Teams messages, Copilot-related content, and unlabeled files copied to USB.

The set is deliberately broad enough to establish meaningful coverage across Microsoft 365 and managed endpoints, but generic enough to deploy as a starting point without assuming customer-specific legal definitions, partner domains, approved applications, exception groups, or risk tolerances. It is therefore intended to deliver most of the practical baseline value quickly; the remaining requirements are expected to come from tenant-specific discovery, simulation results, business exceptions, and regulatory obligations.

Ten policies begin in TestWithNotifications mode so administrators can review matches and user impact before enforcement. The narrow unlabeled-to-USB safeguard is enabled immediately because its condition and blocked activity are explicit and easy to understand.



DLP Policy Overview for Administrators

Each baseline policy contains one rule. The names below are the policy and rule names administrators will see when reviewing or operating the deployment.

Policy Name	Rule Name	Scope and Purpose	Initial Mode
Purview DLP-01 Block External Sharing Internal+	DLP-01 Rule	Exchange, SharePoint, OneDrive, and Teams. Blocks external access when common regulated identifiers, payment data, or credentials are detected; notifies content owners and administrators and generates aggregated alerts.	Test-With-Notifications
Purview DLP-02 Block Anonymous Links Confidential+	DLP-02 Rule	SharePoint and OneDrive. Blocks anonymous-link access to files containing common personal or financial identifiers and shows a policy tip.	Test-With-Notifications
Purview DLP-03 Block Unau-	DLP-03 Rule	Exchange, SharePoint, OneDrive, and Teams. Blocks external access to content with higher-volume personal or financial data but permits a justified override. Ap-	Test-With-

Policy Name	Rule Name	Scope and Purpose	Initial Mode
thorized Guest Domains		proved partner-domain exceptions must be added after deployment.	Notifications
Purview DLP-04 PII Financial Data Exfiltration	DLP-04 Rule	Exchange, SharePoint, OneDrive, Teams, and endpoints. Detects higher-volume personal, identity, tax, payment, and banking data; blocks access with justification-based override and raises alerts. Optional incident reports are sent when a security mailbox is supplied.	Test-With-Notifications
Purview DLP-05 Credentials in Files Hard Block	DLP-05 Rule	SharePoint, OneDrive, Teams, and endpoints. Hard-blocks files containing supported cloud credentials and access tokens and generates alerts; optional incident reporting is available.	Test-With-Notifications
Purview DLP-06 Endpoint Block HC to USB Bluetooth	DLP-06 Rule	Endpoints. Blocks sensitive content from removable media, network shares, printing, clipboard transfer, and unallowed Bluetooth applications. The rule can be limited to elevated-risk users through Adaptive Protection when supported.	Test-With-Notifications
Purview DLP-07 Endpoint Block Upload Unapproved Cloud	DLP-07 Rule	Endpoints. Blocks sensitive personal, financial, identity, and credential data from cloud egress to non-approved services. The rule can use the elevated Adaptive Protection risk level when supported.	Test-With-Notifications
Purview DLP-08 Endpoint Block Unallowed Apps	DLP-08 Rule	Endpoints. Blocks unallowed applications from accessing files that contain supported cloud credentials or tokens. Restricted application groups must be defined in Endpoint DLP settings; Adaptive Protection can restrict the rule to elevated-risk users.	Test-With-Notifications
Purview DLP-09 Teams Block Sensitive Messages	DLP-09 Rule	Teams. Blocks messages containing common personal, financial, banking, or credential data and informs the message owner through a policy tip.	Test-With-Notifications
Purview DLP-10 Copilot Content Protection	DLP-10 Rule	Teams is used as the compatible deployment location. Blocks content containing selected credentials, payment-card data, or U.S. Social Security numbers and generates alerts. Administrators should move the policy to the dedicated Copilot location when that location is available in the tenant.	Test-With-Notifications

Policy Name	Rule Name	Scope and Purpose	Initial Mode
Endpoint DLP - Unlabeled to USB	Block Unlabeled -> USB	Endpoints. Blocks files that have no sensitivity label from being copied to removable media and shows an endpoint notification.	Enable

Required DLP Administrator Follow-Up

Yes. The policies and rules provide the baseline logic, but several tenant-specific settings cannot be safely predetermined. Administrators must complete the following configuration before the baseline is treated as production-ready:

- Onboard and validate endpoints. Windows and macOS devices must be onboarded to Microsoft Purview or Microsoft Defender for Endpoint, report activities in Activity Explorer, and receive the Endpoint DLP configuration. Without onboarding, DLP-04 through DLP-08 and the unlabeled-to-USB policy cannot evaluate device activity.
- Define approved partner domains for DLP-03. Populate the recipient-domain exception with the organization's approved external partner domains. Until this list is maintained, the rule cannot distinguish approved partners from other external recipients.
- Configure Endpoint DLP destinations and applications. Define supported and restricted browsers, service domains, approved and unapproved cloud destinations, restricted application groups for DLP-08, VPN definitions where required, network-share exceptions, and any device or path exclusions beyond the baseline values. These centrally managed settings affect every device-scoped DLP policy.
- Configure alert routing and incident ownership. Supply and validate the security-alert mailbox if incident reports are required for DLP-04 and DLP-05, confirm who receives user and administrator notifications, review alert aggregation thresholds, and assign an operational team to triage, investigate, remediate, and tune DLP alerts.
- Review policy tips and overrides. Validate the wording, help links, notification recipients, business-justification experience, and which rules allow override. Confirm that supported clients display the expected guidance and that override events are monitored.
- Complete evidence collection only if required. If investigators must review copies of matched endpoint files, configure evidence collection, storage, retention, permissions, regional separation, and access controls. This is an optional but separately governed capability.
- Validate the Copilot policy location. DLP-10 uses Teams as a compatible fallback. When the tenant exposes the dedicated Copilot DLP location, move or recreate the policy in that location and retest its behavior.

- Verify Adaptive Protection conditions. If Adaptive Protection is used, confirm that DLP-06, DLP-07, and DLP-08 contain the Elevated-risk condition, risk levels are being assigned, and the block actions are appropriate for that population.

Validation Before Enforcement

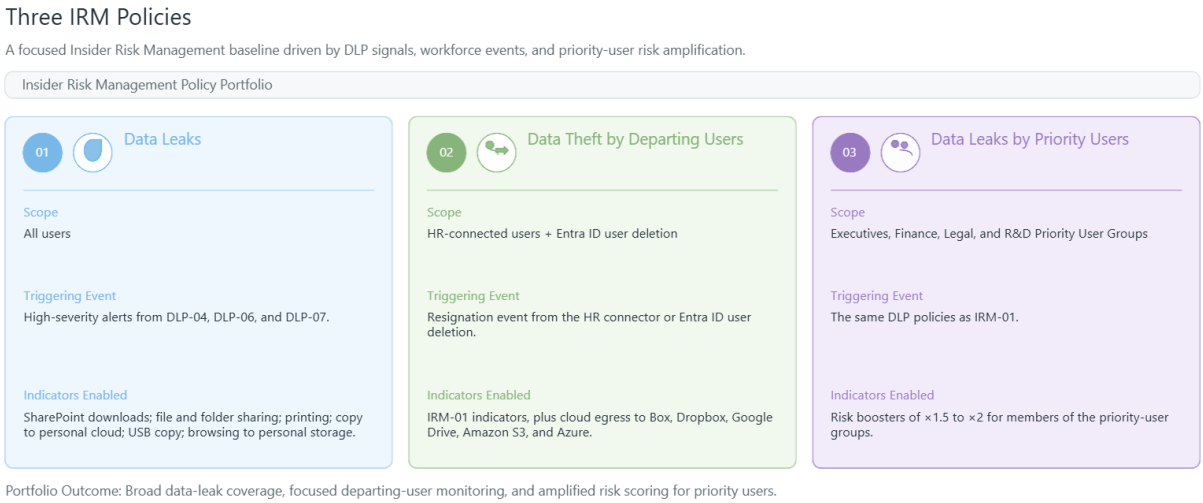
DLP-01 through DLP-10 are intentionally deployed with notifications rather than immediate enforcement. Administrators should review matches, alerts, user overrides, policy-tip behavior, affected workloads, and false positives; confirm that the tenant's sensitive information types resolve as expected; and tune counts, confidence levels, exclusions, scopes, notification text, and alert thresholds. Microsoft recommends simulation and testing because these modes show policy impact without enforcement and support tuning before production rollout. Policies should move to enforcement only after security, compliance, privacy, legal, service owners, and business stakeholders accept the results. The enabled unlabeled-to-USB rule should also be monitored closely and adjusted if legitimate operational workflows are blocked.

Message Encryption in the Starter Kit

Message encryption is the delivery mechanism behind the encrypted sensitivity labels in this baseline, rather than a separate user-facing protection model. When the required Exchange Online and Rights Management capabilities are available, the Starter Kit enables Exchange internal licensing and configures the existing OME configuration for one-time-passcode and social-identity sign-in. This allows external recipients to open protected messages while the label continues to govern access. The organization must still review branding, legal text, support details, and the recipient experience before production use.

- Confidential\Specific People: uses user-defined Encrypt-Only protection. The sender selects trusted internal or external recipients, and the protected content remains encrypted for those recipients.
- Highly Confidential\Specific People: uses user-defined Do Not Forward protection. The sender selects named recipients, and forwarding is restricted to maintain tighter control over highly sensitive content.
- Optional branded templates are not created by the baseline. They can be added later for defined regulatory or business communication scenarios after requirements and recipient behavior have been validated.

Insider Risk Management and Adaptive Protection Baseline



The Starter Kit uses Insider Risk Management (IRM) to add user-risk context to the information protection and DLP baseline. The sensitivity labels define the value and required protection of content, and DLP controls risky handling of that content. IRM adds a separate layer that correlates user activities and triggering events to identify potentially risky behavior. The baseline therefore establishes three complementary policy scenarios rather than attempting to model every insider-risk use case.

Policy Name	Policy Purpose and Rationale	Administrator Configuration Required
IRM-01 Data Leaks	Uses the Data leaks by users template and is intended as the broad organization-wide detection policy. It focuses on potentially risky data-exfiltration activity by users, including activity that can correlate with high-severity DLP alerts. The rationale is to create a general detection layer for accidental or deliberate leakage that is not limited to a special population.	Confirm the users or groups in scope, select the triggering events, enable the relevant exfiltration and other policy indicators, tune thresholds and policy windows, and choose any content priorities or exclusions.
IRM-02 Data Theft Departing Users	Uses the Data theft by departing users template. It focuses risk scoring on resignation, termination, or account-deletion events and looks for data-exfiltration activity near a departure. The rationale is that employment transitions create a distinct and time-bound risk that warrants separate detection and investigation.	Configure a Microsoft 365 HR connector to provide resignation and termination dates or select the Microsoft Entra user-account-deletion trigger as the fallback. Then select indicators, define policy windows and thresholds, and confirm the users in scope.
IRM-03 Data	Uses the Data leaks by priority users template. It applies more focused scoring to us-	Create one or more priority user groups, assign their members, de-

Policy Name	Policy Purpose and Rationale	Administrator Configuration Required
Leaks Priority Users	ers whose access, role, project, or data exposure could make an incident more consequential. The rationale is to give high-impact populations closer inspection without applying the same sensitivity to every user.	fine who may review alerts and cases for each group, bind the appropriate group to the policy, and tune indicators and thresholds for the population.

What the Starter Kit Configures

If the tenant is licensed and the required cmdlets are available, the deployment attempts to enable IRM analytics and anonymization, creates the three named policies from the corresponding templates, and enables Adaptive Protection. The implementation is capability-aware: when a cmdlet, parameter, or license is unavailable, the item is skipped or reported rather than causing the complete deployment to fail.

Required Administrator Follow-Up

Creating an IRM policy object is not sufficient by itself. Global indicators are disabled by default, and a policy does not evaluate a user until its required triggering event occurs. After deployment, an authorized administrator should complete the following configuration in the Microsoft Purview portal:

- Verify licensing, regional availability, permissions, role groups, privacy requirements, investigation ownership, and the intended users or groups in scope.
- Review IRM global settings. Enable analytics if it was not enabled automatically, confirm anonymization, configure administrator notifications, and define global exclusions where necessary.
- Enable the global policy indicators needed by the three templates. Select only signals the organization can investigate and govern, then configure the corresponding policy indicators, thresholds, risk-score boosters, content priorities, and policy windows.
- For IRM-01, select the data-leak triggering event and indicators. If high-severity DLP alerts are used as a trigger, verify that the relevant DLP policies generate the required alerts.
- For IRM-02, configure and operate the HR connector that imports resignation or termination dates, or explicitly use Microsoft Entra account deletion as the trigger. Validate the imported identities and dates before relying on the policy.
- For IRM-03, create priority user groups, assign members, restrict reviewers where appropriate, and select the group in the policy.
- Review policy health, analytics results, users with triggering events, alert volume, and false positives. Tune the policies before treating alerts as operational investigation signals.

Adaptive Protection Binding

Adaptive Protection connects IRM risk levels to preventive controls. The script enables Adaptive Protection when the management interface is available and adds the Elevated risk condition to DLP-06, DLP-07, and DLP-08 when the DLP cmdlet supports that parameter. This means the endpoint controls for removable media and related transfer channels, unapproved cloud upload, and unallowed applications can be applied dynamically to users classified at the Elevated risk level.

The deployment does not create separate Moderate or Minor rule behavior. Administrators must review the Adaptive Protection risk-level definitions, confirm that the Elevated level is appropriate for hard-blocking endpoint actions, and decide whether additional DLP rules are required for Moderate or Minor risk. They should also verify that Adaptive Protection is active, that risk levels are being assigned, that DLP-06 through DLP-08 contain the expected condition, and that the resulting controls are tested before wider enforcement.

References

Microsoft Learn – Purview Sensitivity Labels & Encryption

- Introduction to secure by default with Microsoft Purview
- Learn about sensitivity labels
- Get started with sensitivity labels
- Create and publish sensitivity labels
- Restrict access to content by using sensitivity labels to apply encryption
- Automatically apply a sensitivity label to Microsoft 365 data
- Use sensitivity labels to protect collaborative workspaces (groups and sites)
- Enable sensitivity labels for files in SharePoint and OneDrive
- Configure a label to apply S/MIME protection in Outlook
- Configure Azure Rights Management super users for discovery services or data recovery
- Learn about the Azure Rights Management encryption service
- What is Double Key Encryption (DKE)?
- Set up Double Key Encryption
- Sensitivity Labels in Power BI - Microsoft Purview Information Protection
- Sensitivity labels for Microsoft Teams

Microsoft Learn – Data Loss Prevention

- Learn about data loss prevention
- Plan for data loss prevention (DLP)
- Design a data loss prevention policy
- Data Loss Prevention policy reference
- Create and deploy a data loss prevention policy
- Data loss prevention Exchange conditions and actions reference
- Data Loss Prevention policy tips reference
- Use sensitivity labels as conditions in DLP policies

- Data loss prevention and Microsoft Teams
- Help prevent sharing sensitive items via SharePoint and OneDrive with external users

Microsoft Learn – Endpoint DLP

- Learn about Endpoint data loss prevention
- Get started with endpoint data loss prevention
- Configure endpoint data loss prevention settings
- Endpoint DLP policy scenarios in Microsoft Purview
- Help prevent exposure of sensitive files by configuring auto-quarantine for OneDrive sync
- Help prevent sharing of sensitive items with unauthorized cloud apps and services
- Onboard Windows 10 and Windows 11 devices into Microsoft Purview overview
- Onboard macOS devices into Microsoft Purview
- Microsoft Defender for Endpoint Device Control Removable Storage Access Control
- Learn about Advanced Label Based Protection

Microsoft Learn – Insider Risk Management

- Learn about Insider Risk Management
- Learn about Insider Risk Management policy templates
- Get started with Insider Risk Management
- Configure policy indicators in insider risk management
- Learn about Adaptive Protection in data loss prevention
- Help dynamically mitigate risks with Adaptive Protection
- Share Insider Risk Management data with other solutions

Microsoft Learn – Sensitive Information Types & Classification

- Learn about sensitive information types
- Sensitive information type entity definitions
- Learn about credential sensitive information types
- Learn about trainable classifiers
- Learn about exact data match based sensitive information types